MCP-kategorier og eksponering

301 værktøjer, 28 synlige

Plan 5/11 2026. Spørgsmålet var: site-botten (agenten der taler med sitet over MCP) skal have adgang til **alle** værktøjer på sitet, og de skal sættes i kategorier — i dag ser den **28**, mens serveren annoncerer **301**. Dette dokument er planen: hvad der er målt, hvad kategorier kan og ikke kan, de otte kategorier, de fire risikoklasser, eksponeringsprofilerne og den ene kommando der afgør hvor de 28 kommer fra.

0. Kort version

- **Kategorier er etiketter, ikke tilladelser.** WordPress' ability-kategorier grupperer værktøjer for klienten; de spærrer intet. Det der spærrer er fire andre knapper: rollen, «Drafts Only», «Approvals» og hver abilitys egen `permission_callback`.
- **Vi kan ikke omkategorisere andres værktøjer.** WooCommerce', Rank Maths og AI Engines abilities bærer deres egen kategori, og den ejes af det plugin. Alt andet er en wrapper eller et katalog — ikke en flytning.
- **Ottekategori-planen** (content, media, commerce, seo, social, ai, ops, system) er derfor en kontrakt for botten: den læser kategorien, vælger værktøj og ved hvad den må. Serveren håndhæver den ikke.
- **De 28 er sandsynligvis pagination eller et public-filter, ikke en rettighed.** «Drafts Only» afviser ved kald, ikke ved listning, så en kort liste kan ikke forklares med den. `tools/mcp_rest.py --split` afgør det.
- **301 værktøjer til én bot er en risiko, ikke en milepæl:** 45 af AI Engines 74 kan ændre sitet, og `wp_delete_post` og `wp_delete_media` er blandt dem. Planen giver tre profiler, så "alle" kan betyde "alle nåbare" uden at slette-knappen står åben hele dagen.

1. Hvad der er målt, og hvad der ikke er

Fakta	Værdi	Kilde
Vores egne kategorier	steamgears-tools (26 værktøjer) og steamgears-autopilot (social)	includes/mcp-tools.php:22, includes/abilities.php:12; smoke-testen kræver 26
AI Engines indbyggede værktøjer	74 — 29 læsende, 31 skrivende, 14 admin	kildelæsning af 3.9.0, mcp-vaerktoejer-2026-11-02.md
mcp-adapter	3 meta-værktøjer	mcp-adapter-abilities-2026-11-02.md
Sitet annoncerede	206 (2/11) → 236 (4/11) → 301 (ejer, 5/11)	mcp-auth.md, mcp-skriveadgang-2026-11-04.md
Botten ser	28	ejer, 5/11 — ikke efterprøvet

Ikke målt: navnene på de 301. De findes kun i `tools/list`, og der er ingen credential i den worktree planen er skrevet i. Fordelingen kan derfor ikke tælles op, og kategorierne nedenfor er regler der «skal» køres mod listen — ikke et facit.

2. Hvorfor kategorier ikke er tilladelser

Tre forhold, alle læst i kilden:

1. **Kategorien er et felt på abilityen.** `wp_register_ability()` tager `category`, og `wp_register_ability_category()` registrerer et label og en beskrivelse. Der er ingen `permission_callback` på kategorien — kun på abilityen.

2. **AI Engine laver værktøjsnavnet af ability-navnet** ved at erstatte alt ud over `a-zA-Z0-9_-` med `_` (`labs/mcp-abilities.php:230`), så `steamgears-tools/get-option` bliver `steamgears-tools_get-option`. Navnet bærer altså kategorien med sig, men kun som tekst.
3. **En andens ability kan ikke flyttes.** Vi kan registrere vores egne værktøjer i vores kategorier, og vi kan læse alle abilities med `steamgears-tools/list-abilities` og kalde dem med `call-ability`. Vi kan ikke ændre `woocommerce/*` eller `rank-math/*` til at ligge i `steamgears-tools`.

Konsekvensen for planen: **kategorierne er en aftale med botten, eksponeringen er de fire rigtige knapper.**

Knap	Hvor	Hvad den gør	Hvem kan røre den
mcp_role	AI Engine → Settings → MCP	den WordPress-rolle MCP-tokenet optræder som	ejeren (agenten kan ikke hæve sin egen rolle)
mcp_drafts_only	samme sted	afviser alt uden for 10 draft-safe + 21 post-værktøjer	ejeren — wp_update_option er selv omfattet
mcp_approvals	samme sted	off / deletes / site — godkendelsesguard for sletninger og site-ændringer	ejeren
meta.mcp.public	på hver ability	afgør om abilityen bliver et værktøj i tools/list	den plugin-udvikler der registrerer den

3. De otte kategorier

Fælles for alle: navnet er stabilt, medlemmerne afgøres af reglerne i §5, og standardeksponeringen er sat efter risiko — ikke efter hvilket plugin der ejer værktøjet.

Kategori	Indhold	Typiske værktøjer	Typisk risiko	Standard
content	indlæg, sider, blokke, taksonomier, menuer	wp_get_post, wp_update_post, wp_write_blocks, wp_get_menus	R0–R2	åben
media	attachments, alt-tekst, fremhævet billede	wp_get_media, wp_upload_media, wp_count_media	R1	åben
commerce	produkter, ordrer, kuponer, anmeldelser, lager	wc_get_products, wc_update_product, steamgears-tools/list-products	R1–R2	åben
seo	Rank Math, omdirigeringer, sitemap, IndexNow	wp_update_seo, wp_get_redirects, steamgears-tools/sitemap-audit, indexnow-submit	R1–R2	åben
social	autopilotens kø, publicering, kvalitetsgate	steamgears-autopilot_queue-post, check-post, list-queue, publish	R1–R2	åben
ai	AI Engines egne: vision, generering, embeddings	mwai_vision, mwai_image	R1 + forbrug	åben, men koster penge pr. kald
ops	plugins, temaer, cron, caches, options, rewrites, brugere	wp_list_plugins, set-plugin-state, flush-caches, update-option	R2–R3	lukket som standard
system	ping, ændringslog, undo, approvals, adapter-meta	mcp_ping, mcp_list_changes, mcp_undo_change, steamgears-tools/list-abilities	R0	altid åben

4. De fire risikoklasser

Risiko er en anden akse end kategori, og det er den botten skal læse før den kalder noget.

Klasse	Definition	Eksempler	Krav før kaldet
R0	læser, ændrer intet	wp_get_post, wc_get_products, mcp_ping	ingen
R1	tilføjer nyt, rører ikke eksisterende	wp_create_post (kladde), wp_upload_media	ingen, men resultatet skal rapporteres
R2	ændrer eller flytter eksisterende, kan rulles tilbage	wp_update_post, wc_update_product, trash-post, flush-caches	læs-tilbage + notér undo-vej
R3	sletter eller er uigenkaldelig	wp_delete_post, wp_delete_media, set-plugin-state, update-option	kun efter udtrykkelig ejerbesked, og med en gemt kopi

Reglen om R3 står ikke i koden — den skal stå i bottens instruktioner, fordi serveren kun kan afvise ud fra rolle og «Drafts Only», ikke ud fra hvad opgaven var.

5. Klassificeringsreglerne

Rækkefølgen er bindende: annoteringer først, navn og udsagnsord derefter, manuel overstyring sidst.

1. **Annoteringen vinder.** Bærer abilityen `meta.annotations.readonly`, er den R0; `destructive` gør den R3. Vores egne 52 værktøjer har dem alle (`SGAP_Abilities::meta()`); AI Engines `accessLevel` bruges som erstatning for de 74 indbyggede.
2. **Prefix giver kategori:** `wc_`/`woocommerce` → commerce · `rank_math`/`wp_*redirect*`/`sitemap`/`indexnow` → seo · `mwai_` → ai · `steamgears-autopilot_` → social · `steamgears-tools_` → ops (med undtagelserne i §3) · `mcp_`/`mcp-adapter_` → system · resten af `wp_` → content eller media efter objekt.
3. **Udsagnsordet giver risiko:** `get`/`list`/`count`/`audit`/`status`/`ping` → R0 · `create`/`add`/`upload`/ `insert` → R1 · `update`/`set`/`alter`/`trash`/`flush`/`run`/`publish`/`queue` → R2 · `delete`/`remove`/ `activate`/`deactivate`/ `install` → R3.
4. **Alt andet havner i ukendt** og skal have en manuel linje i overstyringstabellen. Et værktøj uden kategori må ikke arves ind i en åben profil ved et tilfælde.

6. Eksponeringsprofilerne

Tre profiler, fordi "alle 301" betyder tre forskellige ting afhængigt af hvem der holder tokenet.

Profil	Hvem	Indstillinger	Må kalde	Pris
A · Læs	enhver agent, også uden opsyn	mcp_role: editor (eller lavere), drafts_only: on, approvals: off	R0	ingen skriverisiko; kan ikke bruges til opgaver der kræver ændringer
B · Arbejde	den daglige bot	mcp_role: admin, drafts_only: on, approvals: deletes	R0, R1, R2 på kladder og ikke-publiceret indhold	kan ikke publicere eller ændre live-sider; det er den profil der passer til 90 % af arbejdet
C · Fuld	samme bot, når ejeren er til stede	mcp_role: admin, drafts_only: off, approvals: site	alle 301, R3 kun efter besked	hele sitet er skrivbart i den vindues tid profilen står åben

Anbefalingen er **B som standard og C som undtagelse**, skiftet for den ene opgave og tilbage igen — ikke C som permanent tilstand. Profil C er den eneste der giver 301 værktøjer «brugbare»; de øvrige viser dem, men afviser kaldet. Det er hele forskellen mellem "har adgang" og "kan bruge".

7. De 28 mod 301 — tre forklaringer, én kommando

Forklaring	Kendetegn	Sådan afvises eller bekræftes den
Pagination	tools/list svarer med et nextCursor, og klienten viser kun første side	kaldet nedenfor; er der en cursor, er 28 et sideantal, ikke en rettighed
Public-filter	abilities uden meta.mcp.public bliver slet ikke værktøjer	--split viser hvor mange der ligger i ability_bridge; en tom spand betyder at bridgen er slået fra
Rollefilter	tokenets rolle må se, men ikke kalde, visse værktøjer	wp_get_option {"key":"mwai_options","raw":true} viser mcp_role

«Drafts Only» kan **ikke** forklare en kort liste: den afviser ved kald, efter værktøjet er valgt, ikke ved listning. Ser botten 28, er det listaflæsningen der skal undersøges først.

```
python3 tools/mcp_rest.py --check           # ok: true + servernavn
python3 tools/mcp_rest.py --split           # counts, vores, ai_engine, ability_bridge,
mangler_live
python3 tools/mcp_rest.py --call tools/list '{}' | head -c 400   # efter nextCursor
```

8. Rækkefølgen

#	Skridt	Tid	Hvem	Blokeret af
1	Mål de 301: --split plus nextCursor-tjek	0,25 t	agent	OAuth-token
2	Kør klassificeringen mod listen, skriv mcp-kategorier-2026-11-05.csv med kategori og R-klasse pr. værktøj	0,5 t	agent	skridt 1
3	Vælg profil (A/B/C) og sæt de fire knapper	5 min	ejer	—
4	Slå de abilities til der mangler meta.mcp.public, hvis public-filteret er årsagen	0,25 t	ejer eller agent med token	skridt 1–3
5	Skriv profilen og værktøjstallet ind i agent-profilen, så næste pas starter fra en måling	0,1 t	agent	skridt 1–4

Indtil skridt 1 er kørt, er 301 et tal fra ejeren og 28 et tal fra ejeren — ikke to målinger. Planen er designet så den ikke antager at forskellen er 273 værktøjer der mangler adgang; den kan lige så godt være 273 værktøjer der er pagineret væk.

9. Hvad botten aldrig må, uanset profil

1. Kalde et R3-værktøj uden at ejeren har bedt om netop den sletning i den tur.
2. Slå `drafts_only`, `mcp_role` eller `mcp_approvals` fra — det er ejerens beslutning, og `wp_update_option` er selv omfattet af gaten med vilje.
3. Kalde `call-ability` med et værktøj den ikke må kalde direkte. Broen arver abilityens egen `permission_callback`, men den omgår bottens egen R3-regel, og det er den regel der holder.
4. Røre `ai`-kategorien uden at sige hvad kaldet koster; hvert `mwai_*`-kald bruger ejerens kredit.
5. Rapportere et værktøj som "tilgængeligt" fordi det stod i listen. Tilgængelighed er et kald der lykkedes.

10. Det der stadig kræver et menneske

- **OAuth-godkendelsen** — én browser-klikning pr. token; uden den kan skridt 1 ikke køres.
- **Profilvalget** — A, B eller C er en risikobeslutning, ikke en teknisk indstilling.
- **meta.mcp.public på andres abilities** — kræver at det plugin tillader det; ellers er svaret at de 273 ikke kan gøres til værktøjer, kun nås gennem `list-abilities` + `call-ability`.

- **At de 301 faktisk kan bruges** — kun et kald pr. kategori beviser det, og det skal gøres i profil C.